DATA INTEGRITY PROCESS

SOP-003 | Issued under POL-003 — Data Integrity Policy

Document ID: SOP-003
Version: 1.0 — DRAFT
Parent Policy: POL-003 — Data Integrity Policy
Parent Framework: IMF-001 — Information Management Framework
Classification: Internal Use
Owner: Compliance / QA
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Data Integrity Process
Document ID	SOP-003
Version	1.0 — DRAFT
Status	Draft for Review
Parent Policy	POL-003 — Data Integrity Policy
Parent Framework	IMF-001 — Information Management Framework
Document Owner	Compliance / QA
Co-Owner	Information Security
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]
Regulatory Alignment	21 CFR Part 11, EU Annex 11, ICH Q10, GxP (GMP/GLP/GCP/GDP), MHRA Data Integrity Guidance (2018), FDA Data Integrity Guidance (2018), WHO TRS 996 Annex 5

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This Standard Operating Procedure operationalises POL-003 (Data Integrity Policy). It defines the procedures for: conducting and maintaining Data Integrity Risk Assessments (DIRAs), configuring and reviewing audit trails in GxP systems, recording and correcting data per ALCOA+ requirements, conducting data integrity training, and reporting, investigating, and closing data integrity incidents.

IMPORTANT: Data integrity is a patient safety and regulatory compliance issue of the highest order. Regulators treat systematic data integrity failures as evidence of a fundamentally dysfunctional quality system — not merely a procedural lapse. Every person who creates or manages GxP records must understand and apply this SOP.

2. Scope

This SOP applies to all GxP data and electronic records in scope of POL-003: all personnel who create, review, approve, or manage regulated records; all systems holding GxP records; and all regulated activities (GMP, GLP, GCP, GDP, GPvP). It also applies to SOX-relevant IT general controls evidence.

3. Roles and Responsibilities

Role	Responsibility in This SOP
Data Integrity Officer (DIO)	Programme management for all data integrity activities. Owns this SOP. Leads DIRA programme. Reviews audit trail reports. Primary regulatory inspection contact for data integrity matters. Reports to ISSG quarterly.
Compliance / QA	Approves DIRAs. Reviews audit trails. Conducts data integrity audits and self-inspections. Approves CAPAs. Investigates data integrity incidents.
Information Security	Configures and maintains audit trail technical controls. Manages access controls in GxP systems. Validates system clock synchronisation. Supports DIRA technical components.
System Owner	Ensures audit trail functionality is enabled and maintained in their system. Ensures user access controls prevent shared logins. Raises technical issues to Information Security.
Data Custodian (IT)	Implements technical configurations for audit trail, access control, and system clock per this SOP. Supports DIRA technical review. Provides system configuration evidence for inspections.
All GxP Personnel	Record data per ALCOA+ requirements. Apply correct paper and electronic

Role	Responsibility in This SOP
	correction methods. Report suspected data integrity issues immediately to DIO/QA.

4. Process Trigger Events

Trigger	Process Initiated	Section
New GxP system deployed or substantially modified	DIRA — conduct assessment before go-live	Section 5
Existing GxP process changes materially	DIRA — review and update existing assessment	Section 5
New GxP personnel joins or changes role	Training — complete data integrity training before working with GxP data	Section 6
Routine schedule (monthly/quarterly)	Audit Trail Review — periodic review per schedule	Section 7
Suspected or confirmed data integrity failure	Incident — report, triage, investigate, and close CAPA	Section 8
Annual calendar	Annual programme review — update DIRAs, review training	Section 9
Regulatory inspection announced	Inspection readiness — confirm DIRA and audit trail status	Section 9.2

5. Process A — Data Integrity Risk Assessment (DIRA)

A DIRA is a structured assessment of the points in a process where data integrity vulnerabilities exist, the controls in place to mitigate them, and the residual risk. DIRAs are a regulatory expectation and will be requested during GxP inspections (FDA, EMA, MHRA).

5.1 When a DIRA Is Required

- All new GxP systems prior to go-live (must be completed before the system is used for GxP activities)
- Existing GxP systems: where a DIRA does not already exist — complete within 12 months of this SOP's effective date
- Material changes to a GxP system or process (new functionality, change of supplier, process redesign)
- Following a High or Critical data integrity incident
- At least every 3 years for all active GxP systems

5.2 DIRA Process

Step 01	**Scope the Assessment** The Data Integrity Officer and System Owner define the scope: • System or process name and ID • Regulated activities performed in the system (GMP/GLP/GCP etc.) • Data types held (raw data, audit trail, reports, certificates) • User types and access levels • Interfaces with other systems (data imports, exports, integrations) • Paper components of a hybrid process (if applicable) Document scope in the DIRA template. DIRA template is maintained by Compliance / QA.	Responsible **DIO / System Owner**
Step 02	**Map the Data Flow** For each regulated activity in scope, map the complete end-to-end data flow: • Where is the data first created (raw data origin)? • What system(s) does it pass through? • Who reviews, approves, and signs the data at each stage? • Where is it archived? • Who can access it — and with what permissions — at each stage? Draw the data flow diagram in the DIRA template. Identify all handoff points where data transfers between systems, users, or formats.	Responsible **DIO / System Owner / Data Custodian (IT)**
Step 03	**Identify Vulnerabilities** For each stage in the data flow, assess the risk of each of the following vulnerability types: • Unauthorised access: can data be accessed or modified by someone without authorisation? • Undetected modification: can data be changed without the change being captured in an audit trail?	Responsible **DIO / Compliance / QA**

	• Retrospective entry: is there a risk of data being entered after the fact rather than contemporaneously? • Selective deletion: can data (including out-of-specification results) be deleted without a record? • System clock manipulation: can timestamps be altered? • Shared credentials: are there shared or generic accounts that prevent attribution? • Data migration risk: is data transferred between systems in a way that could corrupt or lose records? Record each identified vulnerability in the DIRA vulnerability register.	
Step 04	**Assess Existing Controls** For each identified vulnerability, document the controls currently in place: • Technical controls: audit trail configuration, access control settings, system clock source, encryption • Procedural controls: SOPs, work instructions, training requirements, supervisory checks • Administrative controls: periodic audit trail review, access reviews, system validation For each control, assess whether it effectively mitigates the vulnerability (fully effective / partially effective / not effective).	Responsible **DIO / Information Security / Compliance / QA**
Step 05	**Rate Residual Risk** Rate the residual risk of each vulnerability after existing controls are applied using the following scale: Likelihood: 1 (Rare) / 2 (Unlikely) / 3 (Possible) / 4 (Likely) / 5 (Almost certain) Impact: 1 (Negligible) / 2 (Minor) / 3 (Moderate) / 4 (Major) / 5 (Critical — patient safety or regulatory action risk) Risk Score = Likelihood × Impact • Critical: 15–25 — immediate remediation required before or immediately after go-live • High: 8–14 — remediation plan required within 30 days • Medium: 4–7 — remediation plan required within 90 days • Low: 1–3 — remediation at next scheduled maintenance or review	Responsible **DIO / Compliance / QA**
Step 06	**Define Remediation Actions** For each Critical or High residual risk, define a specific remediation action: • Description of the additional control to be implemented • Responsible owner • Target completion date (Critical: within 30 days; High: within 90 days) • Verification method (how will we confirm the control is effective?) Remediation actions become CAPAs tracked in the quality system. No system with an unmitigated Critical risk may be used for GxP activities.	Responsible **DIO / System Owner / Compliance / QA**
Step 07	**QA Review and Approval** The completed DIRA is submitted to Compliance / QA for review and approval. QA must: • Confirm the scope is complete and the data flow accurately represents the process • Confirm vulnerabilities are comprehensively identified • Confirm risk ratings are appropriate • Confirm remediation actions are adequate for Critical and High risks • Sign and date the DIRA QA may reject a DIRA and require revision before approval.	Responsible **Compliance / QA**

Step 08	**File and Schedule Review** The approved DIRA is filed in the quality management system with the system validation documentation. The DIO records the DIRA in the DIRA Register: • System/process name and ID • DIRA reference number • Date approved • Risk summary (number of Critical/High/Medium/Low findings) • Open CAPA references • Next review date (3 years from approval, or earlier if triggered) The DIRA Register is reviewed at each ISSG quarterly meeting.	Responsible **DIO**

NOTE: When updating an existing DIRA: only the sections affected by the change need full revision. However, the complete DIRA must be re-approved by QA after any update. Version history must be maintained.

6. Process B — Data Integrity Training

6.1 Training Requirements

Personnel Category	Training Required	Frequency	Assessment
All new GxP personnel (pre-commencement)	Core data integrity training: ALCOA+ principles, prohibited practices, correction methods (paper and electronic), incident reporting	Before first access to any GxP system or record	Written assessment — minimum 80% pass mark
All active GxP personnel	Data integrity refresher training	Annual	Completion acknowledgement
Data Integrity Officer	Advanced data integrity training: DIRA methodology, audit trail review, inspection readiness, regulatory guidance updates	Every 2 years or on issue of significant new regulatory guidance	External certification where available
QA personnel	Data integrity audit techniques, CAPA management, inspection preparation	Annual	Completion acknowledgement
System Owners / IT custodians of GxP systems	Technical data integrity controls: audit trail configuration, access management, system clock validation	At system deployment and on material change	Completion acknowledgement

6.2 Training Process

Step 01	**Identify Training Need** Compliance / QA maintains the Training Needs Matrix, which maps each GxP role to its required training curriculum. When a new employee joins, changes role, or when training content is updated, the relevant training need is identified and assigned in the training management system.	Responsible **Compliance / QA / Line Manager**
Step 02	**Complete Training** The individual completes the assigned training within the required timeframe: • Pre-commencement training: must be completed and assessed before first access to GxP systems • Annual refresher: must be completed within the annual training window (typically a 30-day window before the anniversary of the previous completion) • Training must be	Responsible **All GxP Personnel**

	completed using the approved training materials in the validated training management system	
Step 03	**Record Completion** Training completion and assessment results are recorded automatically in the training management system. For externally delivered training, the Compliance / QA team uploads the attendance record and assessment result within 5 business days of completion. Training records must include: trainee name, role, training title and version, completion date, assessment result (pass/fail and score where applicable), trainer name (for instructor-led sessions).	Responsible **Compliance / QA / Training Management System**
Step 04	**Handle Training Non-Compliance** Where a GxP personnel member has not completed mandatory training within the required timeframe: • Line Manager is notified by the training management system • The individual's access to relevant GxP systems is flagged for review — in cases of significant overdue training, access may be suspended pending completion • Compliance / QA records the non-compliance and follows up monthly • Persistent non-compliance is escalated to the DIO and relevant Head of Department	Responsible **Compliance / QA / Line Manager**

7. Process C — Audit Trail Review

Periodic audit trail review is a regulatory requirement and a core mechanism for detecting data integrity issues before they become significant failures. Regulators (FDA, MHRA) specifically look for evidence that audit trails are being actively reviewed — not merely that they exist.

7.1 Audit Trail Review Schedule

System / Activity Type	Review Frequency	Reviewer	Sample Scope
Tier 1 (Extremely Critical) GxP systems	Monthly	QA + DIO	100% of administrator actions; 10% random sample of user transactions
Tier 2 (Highly Critical) GxP systems	Quarterly	QA	10% random sample of transactions; 100% of administrator actions
Tier 3 (Moderately Critical) GxP systems	Semi-annual	QA	5% random sample; all flagged anomalies
All GxP systems — post-batch / post-study	Per batch or study	QA (as part of batch or study record review)	All records associated with the batch or study
All GxP systems — on	Immediately	DIO + QA	Full review of relevant time period

System / Activity Type	Review Frequency	Reviewer	Sample Scope
suspicion of DI issue	on report		and user accounts

7.2 Audit Trail Review Process

Step 01

Extract Audit Trail Data

The reviewer (QA or DIO) requests the audit trail report from the System Owner or Data Custodian (IT) for the relevant system and time period. Audit trail reports must be extracted by a QA or DIO user — operational system users must not extract their own audit trail data for review purposes. The extraction must be documented (date, extractor, system, time period, record count).

Responsible
Compliance / QA / DIO

Step 02

Review for Anomalies

The reviewer examines the audit trail data for the following anomaly patterns: Timestamp anomalies: • Records entered at unusual times (outside normal working hours, on weekends/holidays without authorisation) • Timestamps that predate instrument readings or input events • Multiple records with identical timestamps from different users User account anomalies: • Login activity from inactive accounts • High-volume activity from a single user in a short period • Administrator account activity during non-maintenance periods • Activity from generic or shared account names Data anomaly patterns: • Sequences of deleted or blank entries • Original values that appear implausible or rounded to suspiciously neat numbers • Repeated changes to the same field by the same user • Out-of-specification results not followed by an investigation record System configuration anomalies: • Changes to audit trail settings • Changes to system clock or timezone settings

Responsible
Compliance / QA / DIO

Step 03

Classify and Document Findings

Each finding is classified as: • No action required: anomaly explained by known operational event (e.g., after-hours maintenance, system migration) • Observation: unusual pattern warranting monitoring but no immediate evidence of DI breach • Potential incident: pattern consistent with a data integrity violation — escalate immediately to Section 8 (Incident Process) All findings are documented in the Audit Trail Review Report, including the rationale for each classification. The Report is signed by the reviewer and approved by the DIO or Head of QA.

Responsible
Compliance / QA / DIO

Step 04

File and Escalate

The completed Audit Trail Review Report is filed in the quality management system, linked to the relevant system record. Any Potential Incident findings trigger the Incident Process (Section 8) immediately. Patterns across multiple reviews that suggest systemic issues are escalated to the DIO for a DIRA update. The DIO reports audit trail review

Responsible
DIO / Compliance / QA

	status and findings summary to ISSG quarterly.	

8. Process D — Data Integrity Incident Reporting and Investigation

Any suspected or confirmed data integrity failure must be treated with urgency. Delays in reporting or investigation increase regulatory risk and may affect patient safety where clinical or manufacturing data is involved.

8.1 What Constitutes a Data Integrity Incident

The following events must be treated as data integrity incidents and reported per this process:

- Any evidence of deliberate falsification, backdating, pre-signing, or alteration of GxP records
- Audit trail manipulation — disabling, bypassing, or altering audit trail settings
- Discovery of records created retrospectively without documenting that they are reconstructions
- Use of shared or generic login credentials in a GxP system
- Discovery that out-of-specification or anomalous results were deleted, omitted, or not investigated
- Any paper correction that obscures the original entry rather than correcting per approved method
- Discovery that blank fields were left ambiguous or that data was recorded from unofficial notes without retention of the original

8.2 Incident Reporting and Triage

Step 01	**Report Immediately** Anyone who discovers or suspects a data integrity incident must report it immediately to: • Their direct Line Manager, AND • The Data Integrity Officer (DIO), AND • Compliance / QA Report verbally first, then in writing within 2 hours using the Incident Report Form in the quality management system. Do not attempt to investigate, remediate, or resolve the issue before reporting. Do not discuss the incident beyond those listed above until instructed by the DIO.	Responsible **All Personnel**
Step 02	**Preserve Evidence** The DIO and Compliance / QA immediately take the following preservation steps: • Instruct the Data Custodian (IT) to place the affected system in read-only mode for the relevant data if technically feasible • Extract and secure a copy of the relevant audit trail data — hash the extract to confirm integrity of the evidence • Identify and notify Legal / Compliance — a legal hold may be required over the data • Identify any regulatory submissions, batch records, or clinical trial data that may be affected	Responsible **DIO / Compliance / QA / Information Security**

Step 03	**Initial Triage and Severity Classification** The DIO classifies the incident within 4 hours of receipt of the report: Critical — evidence or strong suspicion of deliberate falsification, fraud, audit trail manipulation, or patient safety impact. Immediate escalation to CISO, Legal, and senior leadership. Regulatory notification assessed within 24 hours. High — systemic failures across a process or system, or a single serious failure affecting a regulatory submission or patient safety without evidence of intent. Formal CAPA initiated within 5 business days. Medium — isolated non-compliance with ALCOA+ requirements, no evidence of intent, no regulatory submission or patient safety impact. CAPA initiated within 30 days. Low — minor procedural non-compliance identified during audit or self-inspection, no reliability impact. Corrective action within 90 days.	Responsible **DIO**

8.3 Incident Investigation

Step 04	**Conduct Root Cause Analysis** For Critical and High incidents: a formal investigation is initiated by the DIO, led by Compliance / QA, with Information Security support for technical forensics. The investigation must: • Establish the facts: what happened, when, where, and which records are affected • Determine root cause: using a structured methodology (e.g., 5-Why, Ishikawa diagram) • Identify scope: are there other records, systems, or processes affected beyond the initial discovery? • Assess impact: have any regulatory submissions, batch releases, or clinical decisions been made based on the compromised data? For Medium incidents: a proportionate root cause investigation is conducted by the System Owner and Compliance / QA within 30 days. For Low incidents: root cause is documented in the corrective action record.	Responsible **DIO / Compliance / QA**

Step 05	**Assess Regulatory Notification** For Critical and High incidents, Legal / Compliance and Compliance / QA jointly assess whether regulatory notification is required: • Have any affected records been included in regulatory submissions (IND, NDA, MAA, etc.)? • Does the incident affect a currently marketed or approved product? • Is voluntary disclosure appropriate to demonstrate transparency with the regulatory authority? This assessment must be completed within 5 business days of the incident being classified as Critical or High. Legal advice must be obtained before any regulatory notification is made.	Responsible **Legal / Compliance / Compliance / QA**

8.4 CAPA and Closure

Step 06	**Define and Implement CAPA** A Corrective Action and Preventive Action (CAPA) must be defined for all incidents Medium and above. The CAPA must address: • Corrective	Responsible **Compliance / QA / DIO /**

	action: immediate steps to correct the specific non-compliance found • Preventive action: systemic changes to prevent recurrence — updated SOPs, training, system configuration, additional controls • Target completion dates: Critical/High CAPAs: within 30 days for corrective action, 90 days for preventive action • Verification: how will effectiveness be confirmed? The CAPA is approved by Compliance / QA and tracked in the quality management system.	**System Owner**
Step 07	**Verify Effectiveness and Close** After the CAPA implementation deadline, Compliance / QA verifies effectiveness: • Have the corrective actions been implemented as described? • Has a follow-up audit trail review confirmed the issue is resolved? • Has training been completed by all affected personnel? • Has the DIRA been updated to reflect the new controls? If verification confirms effectiveness: the CAPA is closed in the quality management system. If not: extend the CAPA with revised actions and dates. All closed CAPAs are reviewed by the DIO quarterly to identify cross-system trends.	Responsible **Compliance / QA**
Step 08	**Report to ISSG** The DIO provides a quarterly data integrity incident summary to ISSG: • Number of incidents by severity (Critical/High/Medium/Low) • Status of open CAPAs • Key themes and trends • Any regulatory notifications made • Planned DIRAs and training completions Significant incidents (Critical or High) are reported to the Board / Audit Committee by the CISO or DIO as appropriate.	Responsible **DIO**

9. Process E — Annual Programme Review

The data integrity programme is reviewed annually by the DIO and Compliance / QA to confirm it remains fit for purpose and aligned with current regulatory expectations.

9.1 Annual Review Scope

Review Component	Action	Responsible
DIRA Register	Confirm all GxP systems have a current (≤ 3 year) DIRA. Identify systems due for review. Initiate overdue DIRAs.	DIO
Incident and CAPA log	Review all incidents from the past year. Identify systemic themes. Confirm all CAPAs are closed or on track.	DIO / Compliance / QA
Audit trail review log	Confirm reviews have been completed per schedule. Review findings trends. Update DIRA where trends indicate new vulnerabilities.	Compliance / QA
Training completion	Confirm all GxP personnel have completed required training. Identify and remediate gaps. Update training materials for regulatory guidance changes.	Compliance / QA
Regulatory landscape	Review FDA, EMA, MHRA, and WHO data integrity guidance published in the past year. Update this SOP and POL-003 where new guidance creates new obligations.	DIO / Compliance / QA
Policy and SOP review	Confirm POL-003 and SOP-003 remain current. Initiate formal review if updates are required.	DIO / Compliance / QA

9.2 Regulatory Inspection Readiness

When a regulatory inspection is announced, the DIO and Compliance / QA conduct a targeted readiness assessment:

- DIRA Register: confirm DIRAs for all in-scope systems are current and approved
- Audit trail review: confirm all scheduled reviews are complete and reports are filed; execute an immediate review for any in-scope system with an overdue review
- Training records: confirm all in-scope personnel training is current; remediate any gaps immediately
- CAPA status: confirm all open CAPAs have current, credible remediation plans
- Evidence pack: prepare a data integrity evidence folder for the inspection team containing: DIRA Register, last 3 audit trail review reports per in-scope system, training completion records, open CAPA summary with status

10. Records Generated by This SOP

Record	Storage Location	Retention Period	Responsible
DIRA (all versions)	Quality management system / system validation file	Life of system + applicable GxP retention period	DIO / Compliance / QA
DIRA Register	Quality management system	Life of programme + 5 years	DIO
Training records	Training management system	Life of employment + 5 years (GxP personnel)	Compliance / QA
Audit Trail Review Reports	Quality management system	Same as the records reviewed (per POL-002 Table 5.1)	Compliance / QA
Incident Reports	Quality management system	Life of programme + 10 years (Critical/High); 7 years (Medium/Low)	DIO / Compliance / QA
CAPA records	Quality management system	Same as incident record	Compliance / QA
Annual Programme Review Report	Quality management system	7 years	DIO

11. Related Documents

Document ID	Title	Relationship
POL-003	Data Integrity Policy	Parent policy — ALCOA+ standard and mandatory requirements this SOP operationalises
POL-002	Data Retention and Disposal Policy	Audit trail records retained alongside primary records per POL-002 Table 5.1
POL-005	System Classification Policy	GxP-flagged systems classified per POL-005 — DIRA scope derived from system classification
POL-006	Computer System Validation and Qualification Policy	Validation of GxP systems includes DIRA as a mandatory component; audit trail validation is part of CSV/CSA
POL-007	Change Management Policy	Uncontrolled change is a leading cause of data integrity failure; DIRA vulnerability assessments (Section 5) frequently identify change control gaps;

Document ID	Title	Relationship
		audit trail review (Section 7) detects uncontrolled changes
POL-008	Access Control Policy	Individual user accounts and access review cadence — supports Attributable requirement of ALCOA+
POL-009	Privileged Access Management Policy	Privileged access to GxP systems is the highest-risk data integrity vector; audit trail review (Section 7) specifically checks for anomalous privileged session events; DIRA vulnerability assessments must include privileged access as a risk vector
POL-010	Information Security Risk Policy	DIRA is the GxP domain-specific instance of the IS risk framework governed by POL-010; DIRA Critical and High findings must be reflected in the organisation-wide Risk Register; this SOP's DIRA Register is a sub-register of the IS Risk Register
POL-011	Business Continuity Policy	Audit trail continuity during DR events is a data integrity obligation — gaps in audit trail records after recovery are SOP-003 incidents; validated state confirmation after DR is required before GxP restart
POL-012	Incident Response Policy	Data integrity incidents — audit trail manipulation, uncontrolled GxP system changes, falsification — are security incidents requiring IRT activation; DIRA is updated post-incident; SOP-003 and POL-012 run in parallel for GxP incidents
POL-015	IT Service Management and Operational Incident Policy	Unplanned GxP system outages trigger POL-015 operational incident process; DIRA must be updated for all P1/P2 GxP operational incidents; audit trail gaps during outages are ALCOA+ completeness issues documented per this SOP
POL-014	Audit Trail and Monitoring Policy	Detailed audit trail configuration requirements referenced in Section 7 of this SOP
SOP-001	Data Classification Process	GxP flag assigned at classification determines which processes in this SOP apply
SOP-005	System Classification Process	GxP regulatory flag on system triggers requirement for DIRA
RACI-001	Roles, Responsibilities and Authorities	Accountability for data integrity activities

— End of Document —

SOP-003 v1.0 DRAFT | [Company Name] | CONFIDENTIAL